

Top 3 Recent npm Supply-Chain Attacks

Immediate Developer Workstation and Project Scan Advisory: TanStack, node-ipc, and Axios npm risks

CRITICAL

HIGH

MEDIUM

INFO

1. Executive Summary

Why this matters

Recent npm supply-chain attacks targeted widely used JavaScript/Node ecosystems and developer tooling paths.

Where risk may live

Affected components can exist inside projects, IDE extensions, package-manager caches, node_modules, and developer workstations.

Scan objective

Perform deterministic IOC/version-based detection, not generic keyword scanning. No findings means no known indicators detected.

2. Timeline

Attack	When	What was compromised	Required action
TanStack	Reported May 2026	84 malicious versions across 42 @tanstack/* packages	Scan @tanstack packages, lockfiles, router_init.js, tanstack_runner.js, .claude/.vscode persistence indicators.
node-ipc	Reported May 2026	Malicious node-ipc@9.1.6, 9.2.3, 12.0.1	Scan lockfiles, node_modules/node-ipc, package caches, and C2/DNS indicators.
Axios	Reported Mar/Apr 2026	axios@1.14.1 and axios@0.30.4 added malicious plain-crypto-js	Scan axios versions, plain-crypto-js, lockfiles, package caches, and build logs.

3. Attack 1: TanStack npm Supply-Chain Compromise

CRITICAL	TanStack npm compromise
What happened	84 malicious versions across 42 @tanstack/* packages were reportedly published. Public advisory details describe a release-chain compromise involving GitHub Actions/OIDC publishing paths and credential-stealing malware.
Impact	Potential malicious package execution, developer workstation exposure, CI/CD risk, and possible credential or secret exposure.
What to detect	Known affected @tanstack/* package names and versions; suspicious versions around the compromise window; @tanstack/setup in optionalDependencies; router_init.js; tanstack_runner.js; persistence indicators in .claude/ and .vscode/.
File / network IOCs	router_init.js SHA-256: ab4fcadaec49c03278063dd269ea5eef82d24f2124a8e15d7b90f2fa8601266c tanstack_runner.js SHA-256: 2ec78d556d696e208927cc503d48e4b5eb56b31abc2870c2ed2e98d6be27fc96
Locations to scan	node_modules/@tanstack/*; package-lock.json; pnpm-lock.yaml; yarn.lock; bun.lock / bun.lockb; .claude/; .vscode/.

4. Attack 2: Malicious node-ipc Versions

CRITICAL	node-ipc malicious releases
What happened	Multiple malicious node-ipc releases were detected: node-ipc@9.1.6, node-ipc@9.2.3, and node-ipc@12.0.1. Reporting states the payload can execute when package code is loaded.
Impact	Potential theft of cloud credentials, SSH key exposure, CI/CD secret exposure, and developer workstation compromise.
What to detect	Compromised node-ipc versions in package manifests and lockfiles; node_modules/node-ipc/node-ipc.cjs; npm/pnpm/yarn caches.
File / network IOCs	node-ipc.cjs SHA-256: 96097e0612d9575cb133021017fb1a5c68a03b60f9f3d24ebdc0e628d9034144 C2/network: sh.azurestaticprovider.net; 37.16.75.69; DNS exfil domain bt.node.js; TXT prefixes xh, xd, xf; DNS resolvers observed 8.8.8.8 and 1.1.1.1
Locations to scan	node_modules/node-ipc/; package-lock.json; pnpm-lock.yaml; yarn.lock; package.json; npm/pnpm/yarn caches.

5. Attack 3: Axios Compromise

HIGH	Axios malicious versions
What happened	Malicious Axios versions were reported: axios@1.14.1 and axios@0.30.4. Public analyses describe a compromised npm maintainer account and a malicious dependency added to Axios manifests.
Impact	Compromised application dependency chain, potential data theft, project build pipeline risk, and developer endpoint exposure.
What to detect	axios@1.14.1; axios@0.30.4; plain-crypto-js, especially plain-crypto-js@4.2.1 or ^4.2.1.
File / network IOCs	Additional dependency indicator: plain-crypto-js / plain-crypto-js@4.2.1. Treat presence in Axios dependency chain as high-confidence exposure indicator.
Locations to scan	package.json; package-lock.json; pnpm-lock.yaml; yarn.lock; bun.lock / bun.lockb; node_modules/axios; node_modules/plain-crypto-js.

6. What Systems Must Be Scanned

System	Scan focus
Developer workstations	Local repos, node_modules, shell history, package caches
VS Code / Antigravity	Extensions and embedded package manifests
Claude Code CLI / Claude Desktop	Tooling directories, extension/runtime package trees
Codex CLI / ChatGPT Desktop	Local app data, extensions, caches, project roots
CI/CD runners	Build workspaces, dependency caches, runner temp folders, secrets exposure logs
Project repositories	package.json, lockfiles, workspace files, vendored packages
npm/pnpm/yarn/bun caches	Cached tarballs and package metadata that may reintroduce malicious versions

7. Package Manager Coverage

Package Manager	Primary Lockfile	Other Important Files	Notes
npm	package-lock.json	npm-shrinkwrap.json, package.json	Most common
Yarn	yarn.lock	.yarnrc.yml, package.json	Yarn Berry may use .yarn/cache
pnpm	pnpm-lock.yaml	pnpm-workspace.yaml, .npmrc, package.json	Common in modern projects
Bun	bun.lockb or bun.lock	package.json	bun.lockb is binary and harder to grep directly
All	package.json	node_modules/package.json	Direct and transitive dependencies

8. Recommended Unified Scanner Script Design

Script name: axios-tanstack-node-ipc.sh

Purpose: detect vulnerable npm packages across macOS systems irrespective of package manager; support quick project scans and broader workstation scans; generate section-wise console output, timestamped readable log files, and summary counts for Critical, High, Medium, and Info findings.

1. Quick project scan

Scans current directory recursively. Best for running from a project root.

2. Whole Mac scan

Scans common project, IDE, cache, application, and temp paths. Slower but more complete.

9. Required Scan Locations

Current directory; ~/Desktop; ~/Documents; ~/Downloads; ~/Projects; ~/Code; ~/Workspace; ~/.npm; ~/Library/pnpm; ~/.pnpm-store; ~/.yarn; ~/.cache/yarn; ~/.vscode/extensions; ~/.cursor/extensions; ~/.antigravity/extensions; ~/.windsurf/extensions; /Applications; ~/Applications; /opt/homebrew; /usr/local; /tmp; /private/tmp.

Detection logic: scan package.json, package-lock.json, npm-shrinkwrap.json, pnpm-lock.yaml, yarn.lock, bun.lock, bun.lockb with special handling, node_modules/*/package.json, IDE extension package.json files, and npm/pnpm/yarn caches.

10. One-Liner Scan Examples

```
# TanStack
grep -rE "@tanstack/(react-router|router-core|router|start)" **/package-lock.json **/pnpm-lock.yaml **/yarn.lock 2>/dev/null
find . -name "router_init.js" -exec shasum -a 256 {} \; 2>/dev/null

# node-ipc
grep -E "node-ipc@(9\.1\6|9\2\3|12\0\1)" **/package-lock.json **/yarn.lock **/pnpm-lock.yaml 2>/dev/null
grep -E "\"node-ipc\", \"(9\1\6|9\2\3|12\0\1)\"" **/package*.json 2>/dev/null
find . -path '*node_modules/node-ipc/node-ipc.cjs' -exec shasum -a 256 {} \; 2>/dev/null

# Axios
grep -E 'axios@(1\14\1|0\30\4)' **/package-lock.json **/yarn.lock **/pnpm-lock.yaml 2>/dev/null
grep -E 'plain-crypto-js' **/package*.json **/*lock* 2>/dev/null
ls node_modules/plain-crypto-js 2>/dev/null && echo "Suspicious plain-crypto-js found"

# Combined
grep -E "@tanstack|node-ipc@|axios@(1\14\1|0\30\4)|plain-crypto-js" \
**/package*.json **/package-lock.json **/pnpm-lock.yaml **/yarn.lock 2>/dev/null

# Bun
bun pm ls | grep -E "tanstack|node-ipc|axios"
```

11. Output and Log File Design

```
Supply Chain Scan Report
=====
Scan Time:
Hostname:
User:
Scan Mode:
Scan Root:
Log File:

Section 1: TanStack Findings
Section 2: node-ipc Findings
Section 3: Axios Findings
Section 4: IOC File Hash Findings
Section 5: C2 / Network IOC References
Section 6: Summary and Recommended Actions
```

12. Severity Language

CRITICAL	Known compromised package/version or matching malicious file hash detected.
HIGH	Suspicious package behavior, lifecycle script, or credential-access pattern detected.
MEDIUM	Risky dependency or related indicator found, manual validation required.
INFO	Package reference found but not confirmed vulnerable.

13. Remediation

- Stop using affected project temporarily.
- Remove node_modules.
- Clean npm/pnpm/yarn/bun cache.
- Upgrade affected packages and regenerate lockfiles.
- Reinstall dependencies from known-good versions.
- If a critical indicator is found, rotate GitHub tokens, npm tokens, SSH keys, AWS keys, GCP keys, Azure secrets, and CI/CD secrets.
- Review shell history, build logs, and outbound connections.

Disclaimer: This scanner performs deterministic IOC and version-based verification against known malicious npm package releases and high-confidence supply-chain indicators. Absence of findings does not guarantee absence of compromise.

Source context: TanStack GitHub advisory GHSA-g7cv-rxg3-hmpx; StepSecurity node-ipc advisory; Microsoft, Endor Labs, StepSecurity, JFrog, and Datadog analyses of Axios compromise.